

# Counting Versus Testing the Destination: A Simulation Study of Layered Defences Against SMS OTP Flooding and Pumping

Naveed Ahmed<sup>a,\*</sup>

<sup>a</sup>*College of Computer and Information Science, Prince Sultan University, Saudi Arabia*

---

## Abstract

Endpoints that send one-time passwords via SMS are abused to waste money (flooding) or to earn part of the termination fee (SMS pumping). We evaluate in simulation a twelve-step defense that draws trust from app attestation, signed sessions, and verification outcomes, against simpler designs and 25 attacker profiles. Attacks with a signature in the request are contained at a low cost to simulated users; a residential attacker with farmed CAPTCHA scores is rationed by refusing half of the first-time users. On the destination, short-window counters of SMS sent per number block, selected at a benign service target, leaked 6 to 48 messages against four concentrated 20-minute pumpers at 0.06 to 0.43 points of attack-free completion, where at the busiest density, the default sequential tests of verification outcomes leaked 19 to 452. Under a second predeclared protocol on seeds and workloads held out from selection, the frozen counter met its leakage and benign-cost claims, leaked no more than the tests in all but 13 of 144 cells, all against an instantly verifying carrier, and failed both service-under-attack claims when the pumper shares blocks with real users. For attacks of up to an hour, unfitted estimates whose crossing is algebraic, not a measured switching point, ordered the policies' mean leakage in 18 of 18 decisive boundary cells with the counter's cold-start bound and 17 with its warm-start bound: the counter loses its advantage against paced or widely spread pumpers.

*Keywords:* SMS pumping, artificially inflated traffic, one-time password, rate limiting, sequential tests, fraud prevention

---

\*Corresponding author.

*Email address:* [nahmed@psu.edu.sa](mailto:nahmed@psu.edu.sa) (Naveed Ahmed)

---

## 1. Introduction

Most online services verify a phone number by sending a code via SMS from an endpoint reachable before any account exists, at a tenth of a cent to twenty cents per message. A flooder makes the service send to numbers it does not own; a pumper sends to a range whose operator shares the termination fee, turning the service’s SMS budget into its income [1]. Twitter’s owner said in 2023 that pumping had cost the company approximately \$60 million a year [2], and Huh et al. found as many attack requests as genuine ones in three months of one large service’s logs [3].

We study the defenses of a registration flow: a baseline of seven controls (v1) and a twelve-step redesign with attested platforms, signed sessions, number checks before a message is paid for, reputation from whether codes were entered, a five-response risk score, and a hard budget. We ask in simulation which attacks it contains against simpler designs, at what cost in completed registrations (RQ1); which layer is responsible (RQ2); when outcome-based reputation separates an attacker from simulated users (RQ3); what rationing costs when it does not (RQ4); and what destination policies cost legitimate users, with and without an attack (RQ5).

Because a pumper is paid only on its partner’s ranges, the study focuses on the destination: under a predeclared comparison, a plain counter of sends per number block leaked less than our sequential tests of code outcomes, and a second predeclared protocol mapped where that holds and fails. We contribute an analysis of eight gaps in the baseline, the design, and an open implementation, measurements of where reputation stops separating and what rationing depends on, both destination-policy comparisons with their failures and collateral damage, and unfitted estimates of when counting leaks less than our tests; Sections 7.1–7.4 provide context.

## 2. Background and related work

*Revenue-share fraud.* In international revenue-share fraud, traffic is generated to an advertised number range, and the termination fee is split along the route [4]. Sahin and Francillon’s 3.14 million test numbers from twelve providers show that the range is the fraudster’s managed asset [5].

33 *Detecting artificially inflated SMS.* Huh et al. trained gradient-boosted trees  
34 on 9.4 million SMS authentication logs from nineteen countries, reaching  
35 89.6% recall at 0.19% false positives on web traffic [3]. Approximately 73% of  
36 web attacks sent four or fewer requests per identity a day, defeating per-entity  
37 limits, and destination signals were the strongest: about 92% zero conversion  
38 for attacks against 21% for genuine traffic. Their detector requires labeled  
39 traffic and acts per request. Their data show that destination aggregation  
40 is informative; we add a controlled comparison of two label-free ways to act  
41 on it per block, from send counts or code outcomes, and of their cost to  
42 users sharing a block. Theirs was not reproduced, so the two are not ranked.  
43 Zalisky and Odarchenko count A2P sends per prefix (a number less its last  
44 three digits) in fixed or rolling five-minute windows and quarantine a prefix  
45 for 24 hours past a day or night threshold [6]. On metadata of two confirmed  
46 incidents fixed windows blocked 95% and 63% of the traffic, and 58% of a  
47 legitimate marketing campaign; counting unique recipients blocked 2% of the  
48 campaign and none of the first incident. Theirs is a send counter judged on  
49 real traffic by messages blocked; ours compares a counter with outcome tests  
50 at a service target, in simulation, by what users sharing a block lose; the  
51 numbers are not comparable.

52 *Defenses in practice.* Twilio’s Fraud Guard blocks regions known for pump-  
53 ing [7], and its SMS Pumping Risk Score advises friction from 60 and refusal  
54 above 90 [8], so graded destination action is established; no product was  
55 benchmarked. CAPTCHA solving is a labor market at approximately \$1 per  
56 thousand [9], open where machine solvers fail [10]; client puzzles [11] were  
57 not evaluated. Residential proxy addresses rotate within minutes [12], and  
58 carrier-grade NAT makes address reputation on cellular networks “all but  
59 infeasible” [13].

60 *Identity and change detection.* One entity can present many identities [14],  
61 and a signed session provides continuity, not scarcity. Our block tests are  
62 Wald’s sequential tests [15] run as Page’s cumulative sums [16]. Quickest  
63 change detection minimizes delay under false-alarm constraints [17], and a  
64 CUSUM’s parameters follow from the error rates it must meet [18]; windowed  
65 statistics and confidence sequences [19] were not evaluated, so ‘testing’ be-  
66 low means our conversion and speed tests only. Step 7 resembles risk-based  
67 authentication [20], and attacks on the code once sent are a separate prob-  
68 lem [21, 22].

### 69 3. Baseline and threat model

70 The baseline, v1, sends a code to any unregistered number behind seven  
 71 controls: reCAPTCHA v3 on web requests only, one message per number per  
 72 minute, five requests per address per minute, a country allow-list, a body-  
 73 length limit, a proxy block, and per-platform caps; bulk and test paths skip  
 74 some checks. Table 1 lists eight assumptions behind these rules and how an  
 75 attacker within the threat model breaks each; the gaps follow from the rules,  
 76 not observed abuse.

Table 1: **v1 Assumptions and How They Fail.**

| Gap | v1 assumes                                             | How it fails                                |
|-----|--------------------------------------------------------|---------------------------------------------|
| A   | A platform header says which app sent the request      | Sending the header reaches every exemption  |
| B   | Five requests per address per minute bound an attacker | A fresh residential address per request     |
| C   | A number given is worth sending to                     | Generated numbers cost as much as real ones |
| D   | An allowed country is a safe destination               | Premium ranges inside it cost far more      |
| E   | Per-key caps bound total spend                         | A wide attack under every cap               |
| F   | Check-then-increment is a rate limit                   | Two racing instances both pass              |
| G   | Bulk and test flags are internal                       | Neither needs stronger authentication       |
| H   | Each check says which check failed                     | Thresholds can be probed one at a time      |

77 *Threat model.* The attacker wants as many messages sent as possible, or  
 78 sent to numbers that pay it. It buys residential proxies and human-like  
 79 reCAPTCHA tokens (about 0.3 cents each), mints fingerprints, generates  
 80 numbers, and knows the thresholds. A pumper also has a colluding operator’s  
 81 ranges, where it may enter codes, report deliveries as failed, build verified  
 82 history, spread over blocks, and buy challenge solutions. It cannot forge an  
 83 attestation, use ranges its partner does not terminate, or make a stranger  
 84 enter a code.

### 85 4. Design

86 No message is paid for before every check passes, and cheap checks run  
 87 first. Trust comes from evidence the client cannot forge, an attestation, a

88 server-signed session, and the fate of earlier codes, though such evidence can  
 89 be manufactured (Section 7.8).

#### 90 4.1. The pipeline and the risk score

91 A request passes the steps of Table 2 until it is refused. Step 0 takes the  
 92 platform only from a valid App Attest or Play Integrity result. Each limit  
 93 and reservation is one atomic Redis operation, but the enclosing steps are not  
 94 one transaction: on the normal path, a refused request returns its per-number  
 95 claims and counter slot, and the hourly budget is reserved only for a message  
 96 about to be enqueued, a reservation rather than a completed dispatch; a crash  
 97 between them can leak reservations (Section 6). Address limits and source  
 98 caps count requests, except that a request Step 11 challenges returns its  
 99 source-cap count. Every outcome after Step 0, except the challenge, returns  
 100 one HTTP 200 body after at least 400 ms, a floor that cannot hide longer  
 101 work.

Table 2: **Twelve Steps and the v1 Gaps They Address.** Gaps of Table 1 in brackets;  
 FB: feedback loop.

| Step | Check                                                                                                       |
|------|-------------------------------------------------------------------------------------------------------------|
| 0    | Proxy block; platform from attestation, never from the header [A]                                           |
| 1    | Signed session bound to a fingerprint; 3 requests per session per 10 min [B]                                |
| 2    | Limits per address, /24 and ASN, lower for hosting ASNs [B, F]                                              |
| 3–4  | reCAPTCHA v3 threshold and origin check, web only                                                           |
| 5    | Number intelligence: cost class, sequential numbers, liveness; reads the<br>block’s verdict stage [C, D, G] |
| 6    | Body length, excluded numbers; test bypass needs a credential [G]                                           |
| 7    | Risk score and tier: allow, delay, challenge, downgrade, block [H]                                          |
| 8    | Per-number backoff, 60 s doubling to 1 h, five a day                                                        |
| 9    | Per-source, platform and country caps with an adaptive multiplier                                           |
| 10   | Operating mode: elevated above 80% of the hourly budget, emergency at<br>100% [E]                           |
| 11   | Reserve hourly count, spend and any destination slot; write state; enqueue;<br>uniform response [E, H]      |
| FB   | Outcomes per key; destination-block tests; denylist of fine keys                                            |

102 Step 7 computes

$$s = \sum_i w_i x_i + w_c \frac{\max(0, \theta - r_{\min})}{\theta} + w_s f + w_m i - w_v v_n - w_f v_f, \quad (1)$$

103 where the  $x_i$  are request signals (CAPTCHA score, hosting ASN, fingerprint  
104 age, session requests, country mismatch, number class),  $r_{\min}$  is the lowest con-  
105 version ratio over the request’s keys (address to destination block),  $\theta = 0.3$ ,  
106  $w_c = 25$ ,  $f$  and  $i$  flag a flooded key and one whose codes are entered within  
107 seconds, and  $v_n$ ,  $v_f$  mark a number and fingerprint with verified history;  
108 other weights are 5 to 25 [23]. Tiers start at 20, 40, 60, and 80: *allow*,  
109 *delay* (a doubling wait), *challenge* ( $-20$  when solved), *downgrade* (push or  
110 WhatsApp), and *block*.

#### 111 4.2. The feedback loop

112 A send resolves as *verified* when its code is entered, *fails* after five in-  
113 correct attempts or two minutes past the delivery receipt, and is *undelivered*  
114 without a receipt in 60 s or with a failed receipt; only the first two count  
115 toward reputation. A positive receipt after a negative one reopens the send;  
116 a late verification reclassifies it, but an issued verdict stands. Each transition  
117 records its effects and its time in the same compare-and-set, and a recovery  
118 sweep completes the work of a dead process; each effect type applies at most  
119 once, and exactly once if the sweep runs within 20 minutes. Reputation  
120 counts land in the transition’s hour, and a block keeps its latest outage fail-  
121 ure time; however, a block’s statistic accumulates in processing order, and a  
122 verdict is dated at the event that completes the crossing; thus, a late event  
123 can backdate a verdict that contains later evidence, moving its expiry and  
124 the next test’s start (by 10 min in one diagnostic). Simulated runs apply  
125 events in time order, but concurrent live instances may not, because a tran-  
126 sition is committed before its effects apply; thus, the same dependence holds  
127 live unless a block’s effects are serialized.

#### 128 4.3. Destination policies

129 A pumper is confined to its partner’s ranges but can rotate numbers  
130 and blocks within them. Destination policies are keyed on the 8-digit block  
131 (10 000 numbers); therefore, protection weakens as a pumper spreads.

132 *Sequential tests.* The conversion statistic assumes that users verify with  $p_\ell =$   
133  $0.8$  and a flooder with  $p_a = 0.1$ : a failure adds  $\ln \frac{1-p_a}{1-p_\ell} = 1.50$ , a verification  
134  $\ln \frac{p_a}{p_\ell} = -2.08$ . The speed statistic assumes that a machine enters a verified  
135 code within five seconds with  $q_a = 0.9$  and a person with  $q_\ell = 0.2$ , because  
136 autofill removes the keystroke [24, 25]; it adds  $1.50$  or  $-2.08$ . A verdict is  
137 issued, and the statistic is reset when either exceeds  $h = \ln 1000 = 6.91$ .

138 The floor  $S_t = \max(-ch, S_{t-1} + \text{increment})$  sets the memory: unbounded  $c$   
 139 is Wald’s test,  $c = 0$  Page’s cumulative sum; the default is  $c = 1$ . A first  
 140 verdict makes the block’s first-time clients pass a challenge for an hour; a  
 141 second within the hour moves them off SMS, refusing those without another  
 142 channel.

143 *Counters.* A counter limits the number of SMS sent per block in a daily or  
 144 short refilling window. Step 11 reserves a slot and decides the stage in one  
 145 atomic operation when an SMS is about to be sent, so concurrent requests  
 146 cannot skip the challenge. Past the limit, a graded counter challenges first-  
 147 time clients, and past twice the limit moves them off SMS; a refusing counter  
 148 refuses. Clients with verified history are exempt from both policies; therefore,  
 149 a code entered on a pumper’s number can buy that number an exemption. A  
 150 token bucket of the same rate (burst 4 or 12; its challenge-tier bucket refills  
 151 independently, unlike RFC 2697’s [26]) and the counter combined with the  
 152 tests were also explored.

#### 153 4.4. Capacity controls

154 Step 9 multiplies its caps by 0.25 to 1.5 according to a baseline job com-  
 155 paring each key with its expected rate, learned from the pipeline’s hourly  
 156 counters; without history, the static cap stands. Verified history avoids adap-  
 157 tive reduction, not the static caps or the budget, which bounds SMS count  
 158 and spend, not vendor or fallback costs.

### 159 5. Leakage estimates and a heuristic crossover

160 We compare the SMS sent to a pumper’s number over an attack of  $T \leq 60$   
 161 minutes, by a pumper that solves no challenge and holds no verified history.  
 162 Against the sequential tests, one reaching  $B$  blocks with  $N$  requests at rate  
 163  $\lambda$  leaks about

$$L \approx \min(N, kB + \lambda\tau), \quad k = \lceil h/1.50 \rceil = 5, \quad (2)$$

164 before its first verdict, where  $\tau$ , the time a send stays unresolved, is the  
 165 resolution timeout plus the delivery delay plus half the timeout worker’s  
 166 period (2.55 minutes) if the carrier never verifies, and seconds if it verifies  
 167 at once. Judged, such a pumper is held for the verdict’s hour; therefore,  
 168 for  $T \leq 60$  Equation (2) also estimates the attack’s total, ignoring prior  
 169 credit and outage suspension. A carrier verifying a share  $\sigma$  of codes with

170 a human-like delay gives the conversion statistic an expected increment of  
 171  $\sigma(-2.08) + (1 - \sigma)(1.50)$ , zero at  $\sigma^* = 0.42$ ; above it, the statistic drifts away  
 172 from a verdict.

173 A counter of  $q$  sends per block opens a window with the block's first  
 174 reserved SMS and closes it after the window length. A pumper that finds its  
 175 blocks' counters empty (a cold start) sends at most

$$L_c \leq \min(N, qBw), \quad w = \lceil T/\text{window} \rceil, \quad (3)$$

176 whatever its carrier does with the codes. If a legitimate send has already  
 177 opened a window on block  $b$ , using  $c_b \geq 1$  slots, the pumper can also take  
 178 the remaining  $(q - c_b)^+$  before at most  $w$  further windows open, so in general

$$L_c \leq \min\left(N, qBw + \sum_{b \text{ open}} (q - c_b)^+\right) \leq \min(N, B(qw + q - 1)). \quad (4)$$

179 Solving challenges doubles these bounds, and a verified history exempts a  
 180 client from them. While neither policy's estimate reaches  $N$ , the cold-start  
 181 bound lies below the tests' estimate when

$$B(qw - k) < \lambda\tau, \quad (5)$$

182 and a warm start adds the residual quota to the left side. Equation (5)  
 183 is the algebraic crossing of two simplified quantities, neither of which is an  
 184 empirically established switching point or a necessary condition: other limits  
 185 can hold either policy below its estimate. A carrier that games outcomes  
 186 may never be judged, so the tests' leakage approaches  $N$ .

187 In the code, every send takes a slot, verified clients' included. If a block's  
 188 sends arrive as a Poisson stream with mean  $m$  per window and all reach the  
 189 counter, a window holds  $1 + X$  of them,  $X \sim \text{Poisson}(m)$ , and the idealized  
 190 share beyond the quota is  $E[(1 + X - q)^+]/(1 + m)$ : 7.3% at  $m = q/2$  and 27%  
 191 at  $m = q$  for  $q = 4$ . This is not a challenge rate: exempt clients take slots  
 192 without challenge, and challenge failures, the second tier and earlier gates  
 193 are ignored. The estimates use only the rules, configuration, and attack rate;  
 194 what an excess send costs a user needs the simulation.

## 195 6. Implementation and evaluation method

196 *Implementation.* Approximately 4000 lines of Python implement the  
 197 pipeline on in-memory and Redis backends. Up to release 2.8.3, the sim-  
 198 ulator's in-memory store let a sorted set expire a fixed time after its first

199 write, whereas Redis kept it while written to; therefore, the simulated outage  
 200 detector and Step 5 lost recent observations. Release 2.9.0 follows Redis in  
 201 every rule compared, checked by differential tests, and every study was rerun  
 202 with it; earlier releases repaired seven replay and concurrency defects, each  
 203 with a regression test. Of 453 tests, 19 used a real `redis-server`, 18 tested  
 204 specific interleavings of two instances, not all. Step 11 was still not one  
 205 transaction: a crash after its reservations leaked reserved slots or resolved  
 206 the send as undelivered. The implementation was a research prototype.

207 *Simulation.* The pipeline runs against scripted vendor fakes on a simulated  
 208 clock. After a warm-up of ten minutes (30 or 130 for pumping), attacks run  
 209 over legitimate traffic at 20 requests per minute. Simulated users verify 80%  
 210 of codes after a lognormal delay (median 22s; 2s for the 20% using autofill);  
 211 70% of numbers are reachable on WhatsApp; 90% of users complete a chal-  
 212 lenge; 20% are returning account holders with a stable fingerprint, a trusted  
 213 number, and verified history; thus, the results for returning users describe  
 214 trusted identities only. Separate random streams provide all scenarios at the  
 215 same seed with the same users.

216 Three behavioral parameters have published counterparts: genuine con-  
 217 version (one provider’s 68% or more [27]; ours 60%–90%) and the never-  
 218 converting destinations and identity churn of Section 2; the rest are assump-  
 219 tions. Attackers (Table 3) draw pool size, rate, and CAPTCHA class per  
 220 seed, which explains 92% [80, 98] of the variance of the farm’s leakage in  
 221 a nested design (ten configurations, three seeds each). Brackets are 95%  
 222 percentile-bootstrap intervals, paired per seed for differences; they describe  
 223 variation under this generator, not uncertainty about real traffic.

224 *Two protocols and their chronology.* A supplementary map (`results/`  
 225 `study_map.md`) gives each study’s seeds. The first protocol, committed  
 226 before its runs, fixed the matched comparison and a robustness study over  
 227 12 Latin-hypercube points (conversion 0.6–0.9 and five other behavioral pa-  
 228 rameters) and a held-out family (60 to 120 attack requests a minute, 50 000  
 229 to 500 000 addresses, heterogeneous legitimate traffic), with claims C1–C5  
 230 that hold if true in 90% of cells, a benchmark convention, not a confidence  
 231 level. The matched comparison changes only the destination policy and, at  
 232 three block densities, selects on tuning seeds the least leakage summed over  
 233 four concentrated pumpers among settings at or above the *tuning target*,  
 234 the default’s completion minus 0.5 points. The robustness study’s first run

Table 3: **Attacker Profiles, Capabilities, and Policies.** Policies faced: S, sequential tests; C, counters; B, block-limit. Parameters: `results/attacker_profiles.md`.

| Capability                          | Profiles                                                                                                                                      | Policies |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|----------|
| A signature in the request (5)      | One address; datacenter rotation abroad; a premium-rate prefix; numbers walked upward; the farm with an unattested iOS header                 | S, B     |
| Looks like a person (7)             | Residential bot; farmed CAPTCHA with fresh or aged fingerprints; one 48-hour-old browser profile                                              | S, B     |
|                                     | Low and slow, 2 or 10 requests/min over 20 ASNs; datacenter rotation buying challenge solutions                                               | S        |
| Games outcomes or trust (8)         | Pumpers on elevated-cost or standard ranges verifying within 1 s, or 60% after 30 s                                                           | S        |
|                                     | Threshold-aware and receipt-faking carriers; three trust builders (500 identity/number pairs verify for 10 or 30 min, then flood)             | S, C     |
| Concentrated on the destination (5) | Four pumpers on three blocks (carrier never verifies, verifies within 1 s or 60% after 30 s, or buys challenges); a poisoner on users' blocks | S, C     |
| Spread (generated)                  | 3 to 300 blocks, at full rate or at most the counter's quota per block                                                                        | S, C     |

failed C1 in 32 of 108 cells because attack and no-attack runs drew different users; we fixed the pairing, a fix that followed a result, and reran every study. The second protocol (claims K1–K5) was written after the matched comparison had selected three counters and committed before its runs; six of its seed values had served other robustness points, never selection. Both were rerun unchanged with 2.9.0 (9 919, 7 925 and 240 runs, each carrying its code hash); against 2.8.0, total leakage changed in 855 of 17 964 comparable runs, but the principal selections, eligibility decisions, and claim counts did not; one auxiliary setting (false alarms matched at unbounded credit) moved from  $T1000$  to  $T300$  under both protocols (artifact change report).

*Designs and metrics.* Seven designs: **v1**, **v1-corrected** (attested platform), **budget-only** (sessions, static caps, budget), **block-limit** (a refusing counter of five sends per block per day), **conversion-only** and **speed-only** (v2 minus one block test), and **v2**. A seed is *contained* when leakage stays at most 5% of the attack rate from some minute to the window's end, for five minutes or more. *Attributable* loss compares the same requests with the policy enforced and absent, net of the reverse, in points of offered users: on attack-free traffic it is the *benign cost*, on the attacked trace the *extra harm* relative to the attacked no-policy arm. *Degradation* compares the attacked trace with attack-free operation under the same policy.

Table 4: **Leakage and User Impact Across Designs.** Leaked share (% , mean of per-run shares) of about 600 attack requests in 20 minutes, 30 seeds, under v1, block-limit (BL) and v2 with source caps lifted, and under v2 with caps on, with first-time users refused and all users completing (%). All designs, with intervals: supplementary Table S1 (results/design\_table.md).

| Attacker            | caps lifted: leaked |      |      | caps on, v2 |         |           |
|---------------------|---------------------|------|------|-------------|---------|-----------|
|                     | v1                  | BL   | v2   | leaked      | refused | completed |
| Single client       | 5.6                 | 0.3  | 0.3  | 0.3         | 1.1     | 79.1      |
| Datacenter rotation | 69.0                | 69.0 | 0.0  | 0.0         | 1.1     | 79.1      |
| Premium pumping     | 99.4                | 1.0  | 0.0  | 0.0         | 1.1     | 79.1      |
| Sequential numbers  | 99.4                | 1.0  | 11.5 | 10.7        | 3.5     | 77.5      |
| Reused profile      | 99.5                | 99.5 | 22.5 | 17.4        | 8.6     | 74.2      |
| Residential bot     | 37.2                | 37.2 | 37.2 | 29.9        | 16.2    | 69.6      |
| Farmed CAPTCHA      | 99.5                | 99.5 | 99.5 | 45.6        | 54.0    | 45.5      |
| Aged fingerprints   | 99.5                | 99.5 | 99.5 | 45.6        | 54.0    | 45.5      |
| Forged header       | 100.0               | 99.5 | 99.5 | 45.6        | 54.0    | 45.5      |

## 255 7. Results

### 256 7.1. RQ1: what is contained, and at what cost

257 Datacenter rotation leaks nothing under v2 because it scores in the chal-  
 258 lenge tier and declines challenges; Step 5 refuses the premium range, and  
 259 the session cap holds the single client to two messages (Table 4); in all 108  
 260 robustness cells, these attacks leaked under 5% at completion within two  
 261 points of the paired no-attack run (claim C1). The walk leaks 61 [53, 70]  
 262 messages before its block’s verdict (block-limit: five), and the reused profile  
 263 89 [83, 95].

264 The farm leaks 99.5% with caps lifted under every design; v2’s adaptive  
 265 cap holds it to 229 [215, 244] messages, 46%, by refusing 54% [47, 60] of first-  
 266 time users, so 45.5% complete instead of 76.4% under v1: rationing (claim  
 267 C5 held in 36 of 36 cells).

### 268 7.2. RQ2: conditional effects of each layer

269 In the ablation grid (90 effects, each conditional on all other layers, un-  
 270 adjusted intervals; artifact), removing the adaptive caps lets the farm leak  
 271 310 [194, 421] more messages; the risk engine, feedback loop, and block key  
 272 hold the walk by 166, 152, and 121 messages, and the loop holds the reused  
 273 profile by 138. The key acts only through the loop (interaction  $-121$   $[-141,$   
 274  $-101]$ ).

275 *7.3. RQ3: where reputation stops separating*

276 A farmed-CAPTCHA attacker uses an address and fingerprint once and  
 277 shares its country, prefix, and residential ASN with every legitimate user;  
 278 thus, its failures penalize everyone: over an hour with caps lifted (five seeds),  
 279 up to twice the legitimate rate, 99 to 100% of it leaks, since a shared key stays  
 280 above 0.3 conversion until failures outnumber legitimate sends about 1.7 to  
 281 one. At ten times, 70% leaks while 17% of legitimate users are challenged  
 282 and 3.2% refused (claim C2, at least 90% leaked with caps lifted, held in 34 of  
 283 36 cells). No single score change separates better: a fresh-fingerprint weight  
 284 of 40 stops it only by challenging 47% of legitimate users. In the settings  
 285 run, reputation separated an attacker only on keys its sends dominated [14].

286 *7.4. RQ4: what rationing costs, and what it depends on*

287 When separation fails, the cap is the lever: over ten seeds, the default lets  
 288 47% of the farm’s requests through and refuses 41% of all legitimate users,  
 289 the tightest setting 20% and 64%. Both assume an oracle job that is told the  
 290 legitimate rate and runs every minute; running every five minutes or hourly,  
 291 it lets 75%–96% through. Learning the rate from the pipeline’s counters, the  
 292 deployed job leaks 193 [161, 229] messages with a clean three-week profile,  
 293 340 [239, 441] more on a cold start, 106 [62, 151] more with a stale profile,  
 294 and 45 [10, 77] more with a poisoned one.

295 *7.5. Pumping against the sequential tests*

Table 5: **Containment Results for Concentrated Pumping Attacks.** Three blocks, caps lifted, ten seeds: messages leaked of about 574 requests in twenty minutes; seeds contained; mean minutes to containment (contained seeds) and to the first verdict (seeds with one); codes entered.

| Carrier, design                     | Leaked (msgs)      | Contained (seeds) | Containment (min) | First verdict (min) | Codes entered |
|-------------------------------------|--------------------|-------------------|-------------------|---------------------|---------------|
| never verifies: v1                  | 570 [419, 736]     | 0/10              | –                 | –                   | 0             |
| v2 default                          | 90 [71, 114]       | 10/10             | 3.5 [3.1, 3.9]    | 3.0                 | 0             |
| verifies within 1 s: v2 default     | 19 [17, 21]        | 10/10             | 1.4 [1.1, 1.7]    | 0.4                 | 19            |
| verifies 60% after 30 s: v2 default | 452 [365, 539]     | 0/10              | –                 | 11.6                | 272           |
| v2 default, 60 min                  | 1 067 [839, 1 310] | 2/10              | 47.0 [42.0, 52.0] | 25.5                | –             |
| buys challenges: v2 default         | 106 [87, 127]      | 10/10             | 4.3 [3.8, 4.9]    | 3.0                 | 0             |

296 In Table 5, the speed test catches a carrier verifying within a second at 19  
 297 messages, while the carrier verifying 60% with human-like delay is contained

in none of the ten 20-minute runs: its first verdict comes at minute 11.6 on average and 452 messages leak; in an hour, 1 067 leak and two of ten runs are contained, at minute 47.0 on average. Claim C3 (containment with at most 30% leaked) held in 36 of 36 cells.

Across 18 spread configurations, leakage follows the blocks touched: with 30 blocks, five to seven runs in ten are still contained. Unsaturated, Equation (2) errs by 1.6 to 7.9 messages per run (1%–13%, ten configurations); saturated, it overstates by up to 91.

### 7.6. Destination policies: where the counter wins, and where it fails

Table 6: **Leakage and Benign-User Impact Across Carrier Types.** First protocol, 200 blocks (144 legitimate sends per block a day), tuning seeds 100–102, evaluation seeds 0–9: 20-minute leakage (messages) by never-verifying (NV), instant (IV), human-like (HL) and challenge-buying (CB) carriers; from 24-hour attack-free runs at 65% conversion, completion, benign cost (points), users challenged and verdict events a day. Tuning target: **63.95%**.

| Setting (selected as)                                           | NV  | IV  | HL  | CB  | Compl. | Benign | Chall. | Events |
|-----------------------------------------------------------------|-----|-----|-----|-----|--------|--------|--------|--------|
| none                                                            | 319 | 566 | 570 | 405 | 64.13% | –      | 1.53%  | 0      |
| sequential <i>T</i> 1000, <i>c</i> 1 (default)                  | 90  | 19  | 452 | 106 | 64.12% | 0.01   | 1.64%  | 6.5    |
| sequential <i>T</i> 300, <i>c</i> 0 (selected at tuning target) | 88  | 14  | 126 | 98  | 63.77% | 0.37   | 6.54%  | 334.3  |
| counter, graded, 4 per 10 min (selected)                        | 24  | 24  | 24  | 48  | 64.07% | 0.06   | 2.38%  | 0      |
| counter, graded, 160 per day (selected daily)                   | 319 | 409 | 408 | 405 | 64.11% | 0.02   | 1.87%  | 0      |

*At a benign service target.* Under the first protocol (Table 6, Figures 1 and 2), the sequential setting selected at the tuning target holds the human-like carrier to 126 messages only by raising 334 false verdict events a day, and misses the target by 0.18 points on seeds 0–9. The graded counter of four sends per block per ten minutes leaks 24 against each outcome-reading carrier and 48 against the challenge buyer, at 0.06 points; counters selected at the sparser settings leak 6 to 18 at 0.15 to 0.35 points (up to 0.43 at 80%). With the full grid and density-specific attacks (E5) the rule selects the same counters, and so do other objectives on the tuning runs (worst-case leakage, a first-time-loss constraint, each attacker alone, 2 000 random mixes), except the instant verifier alone and 3 mixes at 200 blocks; on fresh seeds the counter leaked least of the winners against every attacker but the instant verifier (25, against 15 and 16). On seeds 300–309 the 1 000-block counter falls 0.12 points below its target, yet no seed-and-conversion cell fails the paired check (the evaluation default minus 0.5 points).

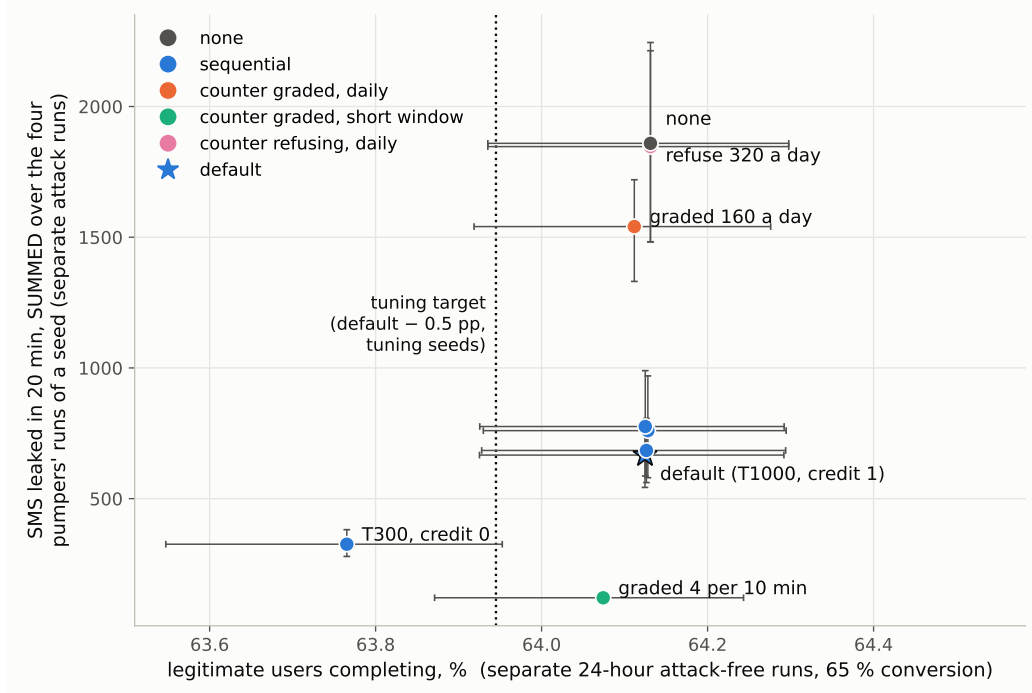


Figure 1: **Leakage vs. Legitimate-User Completion Across Settings.** First protocol, 200 blocks, evaluation seeds 0–9: each setting’s completion in 24-hour attack-free runs at 65% conversion against its 20-minute leakage summed over the four concentrated pumpers’ runs of a seed (not one combined attack). Bars: 95% bootstrap intervals over seeds. Dotted line: the tuning target. Unlabeled points: sequential settings matched to the default’s false alarms at other credits (key: `results/figure1_key.md`).

322 *Under a second protocol.* Frozen and run on the held-out family (Table 7),  
 323 the counter leaked 33, 34, 33, and 62 messages against the four carriers,  
 324 where the default leaked 287, 36, 344, and 287, and no policy 451 to 1857, at  
 325 a benign cost of 0.13 [0.09, 0.17] points, and failed both service-under-attack  
 326 claims: 13 of the 17 cells that broke K3 lie at the three points with the most  
 327 legitimate traffic, where users and pumper compete for one quota; K5 failed  
 328 in 51 cells over 11 of 12 points. The counters selected for sparser traffic cost  
 329 4.7 and 5.8 points here even without an attack: the quota must match the  
 330 traffic.

331 In Table 8, against the attacked no-policy arm, the counter cost all users  
 332 nothing on average and gained the attacked blocks’ users three points on  
 333 average, since without a destination policy, the pumper exhausts their blocks

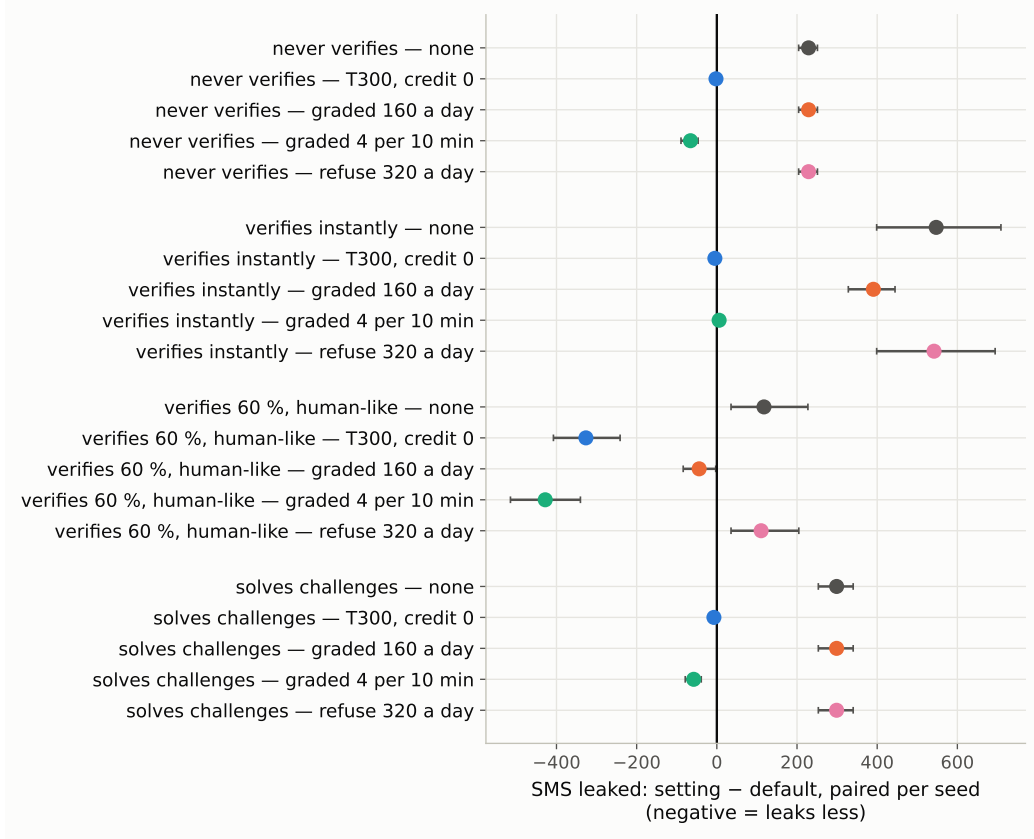


Figure 2: **Leakage Difference from the Default Across Attack Types.** First protocol, 200 blocks, evaluation seeds 0–9, 20-minute attacks: for each selected setting and concentrated pumper, leakage minus the default’s, paired per seed (negative: leaks less), with 95% bootstrap intervals over seeds.

334 and the hourly budget; with the human-like carrier alone, it cost them 1.9.  
 335 Against the attack-free operation, every evaluated policy left those users 5  
 336 to 9 points worse off on average (2 to 12 per carrier; 8 with none): none  
 337 shields a block an attacker shares. Counter and tests together, explored  
 338 outside the frozen claims, leaked least summed over the four carriers but  
 339 not against the instant verifier (28;  $T300, c0$ : 22), and under the poisoner  
 340 (Table 9) cost all users most of the counters and buckets and leaked more  
 341 than  $T300, c0$ . A token bucket with a burst of 4 spared the poisoner’s users  
 342 only by letting almost everything through; with two untuned settings, neither  
 343 limiter dominated, and we ranked only the implemented policies. Returning

Table 7: **Held-Out Evaluation of the Principal Counter.** Second-protocol claims for the graded counter of 4 per 10 min on the held-out family: 12 shifted points, held-out attack rates and pools, three seeds each, a 20-minute pumper on three blocks real users share. A claim holds if true in 90% of cells; cells share workloads and seeds and are not independent. IV: the instant verifier’s cells.

| Claim | Statement                                                             | True / cells   | IV    | Result                   |
|-------|-----------------------------------------------------------------------|----------------|-------|--------------------------|
| K1    | Leaks at most 10% of attack requests                                  | 144/144 (100%) | 36/36 | holds                    |
| K2    | Attack-free attributable loss at most 0.5 points                      | 36/36 (100%)   | –     | holds                    |
| K3    | Attributable loss under attack at most 0.5 points                     | 127/144 (88%)  | 32/36 | fails                    |
| K4    | Leaks no more than the default sequential tests                       | 131/144 (91%)  | 23/36 | holds pooled, not for IV |
| K5    | Attributable loss under attack at most the default’s plus 0.25 points | 93/144 (65%)   | 23/36 | fails                    |

344 users, all simulated with verified history, lost nothing.

Table 8: **Leakage and User Harm Under Shared-Block Pumping.** E1: a pumper on three blocks that real users share; 200 blocks, 60-minute attacks, seeds 300–309, four carriers. Leaked: SMS to the attacker’s numbers, summed over the four carriers’ runs of a seed, which can hide a carrier on which a policy loses (per carrier: artifact). Harm: net completions lost, in points, averaged over the carriers; negative: a gain. Brackets, on leakage and the attacked blocks only: 95% bootstrap intervals over seeds.

| Policy                              | Leaked (SMS)            | Extra harm against attacked, no policy |                                  | Degradation against attack-free, same policy |                    | Benign cost |
|-------------------------------------|-------------------------|----------------------------------------|----------------------------------|----------------------------------------------|--------------------|-------------|
|                                     |                         | all users ( $\approx 1200$ )           | attacked blocks ( $\approx 18$ ) | all users                                    | attacked blocks    |             |
| none                                | 5 509<br>[4 409, 6 567] | –                                      | –                                | 0.19                                         | 8.0<br>[5.1, 10.7] | –           |
| sequential, default                 | 1 149<br>[953, 1 340]   | –0.07                                  | –1.0<br>[–2.8, 0.8]              | 0.10                                         | 7.0<br>[4.7, 9.1]  | 0.02        |
| sequential <i>T</i> 300, <i>c</i> 0 | 397<br>[312, 481]       | 0.13                                   | 0.9<br>[–1.3, 3.3]               | 0.12                                         | 8.9<br>[6.0, 11.7] | 0.20        |
| counter, 4 per 10 min               | 403<br>[386, 418]       | –0.05                                  | –3.2<br>[–5.0, –1.1]             | 0.07                                         | 4.8<br>[2.9, 6.7]  | 0.07        |
| counter + sequential                | 190<br>[179, 201]       | –0.04                                  | –3.1<br>[–5.1, –0.7]             | 0.07                                         | 4.9<br>[3.0, 6.8]  | 0.08        |
| token bucket, burst 4               | 424<br>[412, 437]       | –0.12                                  | –3.1<br>[–5.1, –0.7]             | 0.07                                         | 4.9<br>[2.8, 7.0]  | 0.00        |
| token bucket, burst 12              | 545<br>[531, 559]       | –0.11                                  | –2.1<br>[–4.3, 0.2]              | 0.08                                         | 5.9<br>[3.3, 8.8]  | 0.00        |

Table 9: **User Harm Under a Full-Block Poisoning Attack.** E1: a poisoner flooding all 200 blocks; 60-minute attacks, seeds 300–309. Extra harm: net completions lost, in points of all users (with 95% bootstrap intervals over seeds) and of first-time users.

| Policy                              | Leaked (SMS) | Extra harm against attacked, no policy |                  |
|-------------------------------------|--------------|----------------------------------------|------------------|
|                                     |              | all users                              | first-time users |
| none                                | 1 976        | –                                      | –                |
| sequential, default                 | 1 357        | 1.09 [0.59, 1.59]                      | 1.36             |
| sequential <i>T</i> 300, <i>c</i> 0 | 858          | 2.55 [2.04, 3.07]                      | 3.20             |
| counter, 4 per 10 min               | 1 662        | 0.72 [0.44, 1.02]                      | 0.91             |
| counter + sequential                | 1 286        | 1.43 [0.88, 1.97]                      | 1.79             |
| token bucket, burst 4               | 1 877        | 0.12 [0.04, 0.23]                      | 0.16             |
| token bucket, burst 12              | 1 974        | 0.00 [0.00, 0.00]                      | 0.00             |

345      Attack-free (Figure 3a), the counter costs a block’s users nothing at one  
346      send per ten minutes, 2.3 points at four and 5.5 at eight, far below the

347 idealized share beyond the quota (27% at four), since most challenged users  
 348 complete or switch to WhatsApp; without WhatsApp, eight sends cost 13.2.  
 349 A 30-minute launch at three times the normal rate costs its blocks' users  
 350 16 points. Over 60 minutes (Figure 3c) the default leaked 110, 144 and 242  
 351 messages on 3, 10 and 30 blocks, against 105, 139 and 240 from Equation (2)  
 352 ( $\lambda\tau \approx 90$ ), and the counter 71, 240 and 679 against its cold-start bound  
 353 of 72, 240 and 720. Once 7 messages sent, exempt, to real users' trusted  
 354 numbers are set aside, no counter run that started cold (44 of 100) exceeded  
 355 Equation (3); three warm ones did, by 5 or 6 messages, and none exceeded  
 356 Equation (4). With these unfitted inputs Equation (5) ordered the policies'  
 357 mean leakage in 18 of 18 decisive cells (two ties at  $N$ ), and with the warm-  
 358 start term in 17, missing where the estimates differ by 0.8 messages (30  
 359 blocks, 20 minutes; measured difference 6.6  $[-27.2, 42.4]$ ); per seed, 76 of 78  
 360 decisive comparisons agree. The algebraic crossing lies near five blocks for  
 361 an hour and 30 for twenty minutes, where the nearest measured differences  
 362 (three and 30 blocks) do not exclude zero; it is not a measured switching  
 363 point. Paced to the quota, a pumper leaks about as much under the counter  
 364 as with no policy (71 against 72 on three blocks in an hour), and 23 under  
 365 the tests.

366 Against adaptive attackers (E3), the counter held the threshold-aware  
 367 carrier, receipt faker, and concentrated trust builder to 24 to 36 messages  
 368 (502 to 665 under the default), but not trust builders on random numbers  
 369 (577, as under the default); over 360 minutes, the human-like carrier gained  
 370 81 messages an hour under the counter, and 753 under the default.

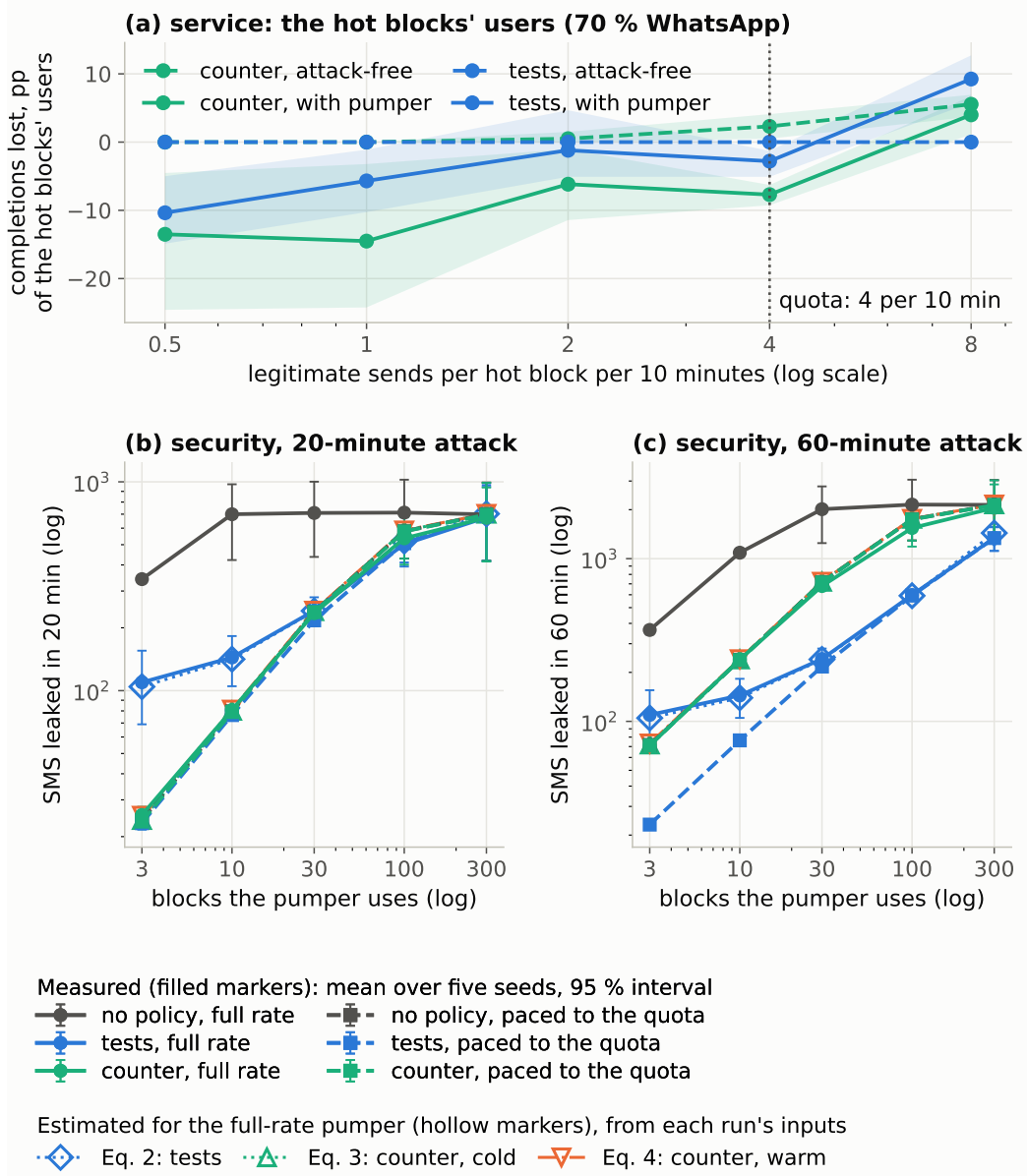


Figure 3: **Operating Boundary of the Counter.** E4, seeds 300–304; lines join sampled settings and do not locate a crossover. (a) Attributable loss in points of the three hot blocks' users against their legitimate rate, attack-free and with a never-verifying pumper on those blocks. (b, c) Leakage in 20 and 60 minutes against the blocks a pumper uses, at full rate or paced, and Equations (2)–(4) for the full-rate pumper (hollow markers). All horizontal axes and the vertical axes of (b, c) are logarithmic. Bands and bars: 95% bootstrap intervals over seeds.

371 *7.7. RQ5: what destination policies cost legitimate users*

372 On one block, 20 000 Monte Carlo trials per cell give the probability of a  
373 verdict within 30 legitimate sends: 0.09% [0.06, 0.14] at 80% conversion with  
374 20% autofill, 1.9% at 65% and 19.5% at 50%. Over 24 hours, the default  
375 raises 0.5 verdict events a day on 200 busy blocks at 80% conversion and 6.5  
376 at 65%, where they meet 30 of about 28 800 requests (claim C4 held in 18 of  
377 18 cells).

378 A poisoner flooding for 20 min the 20 blocks legitimate users concentrate  
379 on (caps lifted, ten seeds) raises 16 verdict events meeting 98 legitimate  
380 requests, 33 never completing; against observe-only operation on the same  
381 trace, enforcement costs 12.7 [4.6, 22.9] completions, 3.1% of users (6.3%  
382 without WhatsApp; 23.9% with a 24-hour denylist). One that stops after  
383 ten minutes leaves verdicts meeting 406.5 requests afterwards, an attributable  
384 loss of 46.2 [16.9, 79.8]. Grading limits the harm; it caps it neither at the  
385 challenge nor at the attack’s duration.

386 *7.8. Adaptive attackers, economics and overhead*

387 The leakages of these scripted adaptations are not bounds. Against v2  
388 with caps lifted, a datacenter attacker buying every challenge solution leaks  
389 55, and a threshold-aware carrier and a receipt faker leak 570 each, drawing  
390 no verdict.

391 If pumpers earn a share of the 0.1422 USD retail price and pay an event-  
392 level bill, they break even at a share of 0.043 under v1 and 0.054 to 0.271  
393 under v2 (the instant verifier 1.310); over 360 minutes under the counter,  
394 the human-like carrier needs 1.048. These are break-even shares for scripted  
395 attackers under assumed prices, not bounds or criminal profit.

396 On a real Redis (four vCPUs, four workers), sends cost 13.8 ms (me-  
397 dian) and 21.1 ms (99th percentile), and 133 requests per second passed at  
398 concurrency 128 with the 400 ms floor and 50 ms vendor calls. With fast  
399 vendors, response times distinguished no pair of five outcome classes (small-  
400 est Kolmogorov–Smirnov  $p = 0.051$ ). Under an adversarial mixture, 81% of  
401 sends overran the floor, and response-time thresholds separated sends from  
402 refusals with 88% balanced accuracy on the fitted run and, fitted on a new  
403 run, 95 to 99.9% on two others: a separation on that machine, not a deploy-  
404 ment accuracy.

## 405 8. Discussion

406 *Lessons.* In the scripted workloads, carriers that verify with human-like de-  
407 lay, fake receipts, or know the thresholds defeated our outcome tests but not  
408 a short-window counter. Within an hour of a verdict, the counter’s allowance,  
409 unlike the tests’, grows with the windows an attack spans; over longer cam-  
410 paigns, verdicts expire and the tests leak again. Equation (5) summarizes  
411 this for pumpers that solve no challenge and hold no exemption. Its inputs  
412 are in an operator’s logs; the cost of an excess send, competition under at-  
413 tack, and exemption abuse come only from the simulation. The counter and  
414 tests together, with a quota set from each block’s traffic, is a hypothesis for  
415 real traffic, not a recommendation.

416 *Limitations.* Everything was simulated, and calibration was assumed. Both  
417 protocols were written by the author for the author’s generator, the second  
418 knowing which counters had won. Some results follow from the generator (a  
419 perfect premium list, a datacenter attacker that declines challenges, returning  
420 users who always present verified history), and selection used an unweighted  
421 sum of four scripted pumpers’ leakage and a mean service target met on tun-  
422 ing seeds, which guarantees no service level elsewhere. Close rankings rest  
423 on ten or fewer seeds, and costs that round to zero are not shown equivalent.  
424 Per-client quotas within a block, carrier spend ceilings, bounded exemptions,  
425 tuned token buckets, and other sequential statistics lie outside the evalu-  
426 ated policies. Vendor adapters are untested live, and the timing result holds  
427 only for the observer tested. Destination policies challenge people for what  
428 strangers sharing their block did, and deployment under the GDPR or Saudi  
429 Arabia’s PDPL needs a lawful basis and a route for refused users. Replaying  
430 real traffic is the experiment this paper most needs.

## 431 9. Conclusion

432 In this simulation, the design contains attacks that carry a signature at  
433 a low cost to simulated users and rations, rather than separates, residential  
434 attackers that resemble people. Counting sends on the destination leaked less  
435 in aggregate than our outcome tests against concentrated pumpers, although  
436 not reliably against an instantly verifying carrier; a frozen counter failed  
437 its service claims when the attacker shared blocks with real users and lost  
438 its advantage against wide, paced, and trust-building pumpers. Within an  
439 hour, unfitted estimates ordered the policies’ mean leakage in 18 of 18 decisive

440 boundary cells with the cold-start bound and 17 with the warm-start bound,  
441 missing a near tie; the crossing was algebraic, not a measured switching point.

## 442 **CRediT authorship contribution statement**

443 **Naveed Ahmed:** Conceptualization, Methodology, Software, Valida-  
444 tion, Investigation, Writing – original draft, Writing – review & editing.

## 445 **Declaration of competing interest**

446 The author declares no known competing financial interests or personal  
447 relationships that could have appeared to influence this work.

## 448 **Declaration of generative AI and AI-assisted technologies in the** 449 **writing process**

450 The author used Claude (Anthropic) for code, evaluation, drafting and  
451 editing; checked numbers against the recorded results and claims against the  
452 code; and takes full responsibility for the content.

## 453 **Data availability**

454 No human or real traffic data was used. Code, protocols (`config/`), every  
455 run’s configuration and outcome and the sources of headline numbers  
456 (`results/`) are at <https://github.com/nahmedpsu/OTP-DDOS>, release  
457 2.9.1 (tag v2.9.1), which runs unchanged the code of release 2.9.0 (tag  
458 v2.9.0, commit 9af3100) that produced the results (`code_identity.md`);  
459 the 2.8.0 results are in `results/historical_2.8`. These files are the  
460 supplementary material.

## 461 **References**

462 [1] MITRE Corporation, Resource hijacking: SMS pumping, technique  
463 T1496.003, MITRE ATT&CK, [https://attack.mitre.org/techn](https://attack.mitre.org/techniques/T1496/003/)  
464 [iques/T1496/003/](https://attack.mitre.org/techniques/T1496/003/), accessed 2026-10-01.

- 465 [2] Commsrisk, Elon Musk says Twitter lost \$60mn a year because 390  
 466 telcos used bot accounts to pump A2P SMS, [https://commsrisk.co](https://commsrisk.com/elon-musk-says-twitter-lost-60mn-a-year-because-390-telcos-used-bot-accounts-to-pump-a2p-sms/)  
 467 [m/elon-musk-says-twitter-lost-60mn-a-year-because-390-tel](https://commsrisk.com/elon-musk-says-twitter-lost-60mn-a-year-because-390-telcos-used-bot-accounts-to-pump-a2p-sms/)  
 468 [cos-used-bot-accounts-to-pump-a2p-sms/](https://commsrisk.com/elon-musk-says-twitter-lost-60mn-a-year-because-390-telcos-used-bot-accounts-to-pump-a2p-sms/), trade press; the figure  
 469 is the company’s own claim (2023).
- 470 [3] J. H. Huh, H. Shin, S. Ahn, H. Yi, J. Cho, T. Kim, M. Lim, N. Choi,  
 471 Preventing artificially inflated SMS attacks through large-scale traffic in-  
 472 spection, in: 34th USENIX Security Symposium, USENIX Association,  
 473 Seattle, WA, 2025.
- 474 [4] M. Sahin, A. Francillon, P. Gupta, M. Ahamad, SoK: Fraud in telephony  
 475 networks, in: 2017 IEEE European Symposium on Security and Privacy  
 476 (EuroS&P), IEEE, 2017. doi:10.1109/EuroSP.2017.40.
- 477 [5] M. Sahin, A. Francillon, Understanding and detecting international rev-  
 478 enue share fraud, in: Network and Distributed System Security Sympo-  
 479 sium (NDSS), Internet Society, 2021. doi:10.14722/ndss.2021.24051.
- 480 [6] M. Zaliskyi, M. Odarchenko, Artificially inflated traffic in A2P mes-  
 481 saging: Window-based detection models and prefix-level analysis for  
 482 fraud mitigation, Science-Based Technologies 69 (1) (2026) 89–98. doi:  
 483 10.18372/2310-5461.69.20735.
- 484 [7] Twilio Inc., Verify fraud guard, [https://www.twilio.com/docs/veri](https://www.twilio.com/docs/verify/preventing-toll-fraud/sms-fraud-guard)  
 485 [fy/preventing-toll-fraud/sms-fraud-guard](https://www.twilio.com/docs/verify/preventing-toll-fraud/sms-fraud-guard), accessed 2026-10-01.
- 486 [8] Twilio Inc., SMS pumping risk score (Lookup v2), [https://www.twilio](https://www.twilio.com/docs/lookup/v2-api/sms-pumping-risk)  
 487 [.com/docs/lookup/v2-api/sms-pumping-risk](https://www.twilio.com/docs/lookup/v2-api/sms-pumping-risk), accessed 2026-10-01.
- 488 [9] M. Motoyama, K. Levchenko, C. Kanich, D. McCoy, G. M. Voelker,  
 489 S. Savage, Re: CAPTCHAs – understanding CAPTCHA-solving ser-  
 490 vices in an economic context, in: 19th USENIX Security Symposium,  
 491 USENIX Association, 2010.
- 492 [10] A. Dionysiou, E. Athanasopoulos, SoK: Machine vs. machine – A sys-  
 493 tematic classification of automated machine learning-based CAPTCHA  
 494 solvers, Computers & Security 97 (2020) 101947. doi:10.1016/j.cose  
 495 .2020.101947.

- 496 [11] D. Dean, A. Stubblefield, Using client puzzles to protect TLS, in: 10th  
497 USENIX Security Symposium, USENIX Association, 2001.
- 498 [12] X. Mi, X. Feng, X. Liao, B. Liu, X. Wang, F. Qian, Z. Li, S. Alrizah,  
499 L. Chen, Y. Qian, Resident evil: Understanding residential IP proxy  
500 as a dark service, in: 2019 IEEE Symposium on Security and Privacy  
501 (S&P), IEEE, 2019. doi:10.1109/SP.2019.00011.
- 502 [13] P. Richter, F. Wolsing, A. Chandrasekaran, R. Padmanabhan, M. All-  
503 man, R. Bush, A. Feldmann, A multi-perspective analysis of carrier-  
504 grade NAT deployment, in: Proceedings of the 2016 ACM Internet  
505 Measurement Conference (IMC), ACM, 2016. doi:10.1145/298744  
506 3.2987474.
- 507 [14] J. R. Douceur, The Sybil attack, in: Peer-to-Peer Systems (IPTPS  
508 2002), Vol. 2429 of LNCS, Springer, 2002, pp. 251–260. doi:10.100  
509 7/3-540-45748-8\_24.
- 510 [15] A. Wald, Sequential tests of statistical hypotheses, The Annals of Math-  
511 ematical Statistics 16 (2) (1945) 117–186. doi:10.1214/aoms/1177731  
512 118.
- 513 [16] E. S. Page, Continuous inspection schemes, Biometrika 41 (1/2) (1954)  
514 100–115. doi:10.2307/2333009.
- 515 [17] V. V. Veeravalli, T. Banerjee, Quickest change detection,  
516 arXiv:1210.5552 (book chapter) (2012).
- 517 [18] NIST/SEMATECH, CUSUM control charts, section 6.3.2.3, e-handbook  
518 of statistical methods, [https://www.itl.nist.gov/div898/handbook](https://www.itl.nist.gov/div898/handbook/pmc/section3/pmc323.htm)  
519 [/pmc/section3/pmc323.htm](https://www.itl.nist.gov/div898/handbook/pmc/section3/pmc323.htm), accessed 2026-10-02.
- 520 [19] S. R. Howard, A. Ramdas, J. McAuliffe, J. Sekhon, Time-uniform, non-  
521 parametric, nonasymptotic confidence sequences, The Annals of Statis-  
522 tics 49 (2) (2021) 1055–1080. doi:10.1214/20-AOS1991.
- 523 [20] S. Wiefeling, L. Lo Iacono, M. Dürmuth, Is this really you? An empirical  
524 study on risk-based authentication applied in the wild, in: ICT Systems  
525 Security and Privacy Protection (IFIP SEC 2019), Vol. 562 of IFIP Ad-  
526 vances in Information and Communication Technology, Springer, 2019,  
527 pp. 134–148. doi:10.1007/978-3-030-22312-0\_10.

- 528 [21] C. Mulliner, R. Borgaonkar, P. Stewin, J.-P. Seifert, SMS-based one-  
529 time passwords: Attacks and defense, in: Detection of Intrusions and  
530 Malware, and Vulnerability Assessment (DIMVA 2013), Vol. 7967 of  
531 LNCS, Springer, 2013, pp. 150–159. doi:10.1007/978-3-642-39235-  
532 -1\_9.
- 533 [22] H. Siadati, T. Nguyen, P. Gupta, M. Jakobsson, N. Memon, Mind your  
534 SMSes: Mitigating social engineering in second factor authentication,  
535 Computers & Security 65 (2017) 14–28. doi:10.1016/j.cose.2016.  
536 09.009.
- 537 [23] N. Ahmed, OTP Guard: a layered SMS validation, risk-scoring and  
538 rate-limiting pipeline against OTP flood abuse (version 2.9.1), <https://github.com/nahmedpsu/OTP-DDoS>, tag v2.9.1, results produced by  
539 2.9.0 (commit 9af3100), whose executable code 2.9.1 keeps; 2.8.0 results  
540 (commit 1c277a0) in results/historical\_2.8 (2026).
- 542 [24] Google LLC, SMS retriever API overview, <https://developers.google.com/identity/sms-retriever/overview>, accessed 2026-10-01.  
543
- 544 [25] Web Incubator Community Group, WebOTP API, <https://github.com/WICG/WebOTP>, accessed 2026-10-01.  
545
- 546 [26] J. Heinanen, R. Guerin, A single rate three color marker, RFC 2697,  
547 Internet Engineering Task Force (1999). doi:10.17487/RFC2697.
- 548 [27] Twilio Inc., Verify API, <https://www.twilio.com/en-us/user-authentication-identity/verify>, accessed 2026-10-03.  
549